

OPNsense - Mise en place d'une PKI

Problématique :

L'utilisation de certificats auto-signés pour les services web internes génère des alertes de sécurité dans les navigateurs et dégrade la confiance des utilisateurs.

Solution :

Mise en place d'une PKI (Public Key Infrastructure) interne à deux niveaux sous OPNsense, avec une autorité racine et une autorité intermédiaire, délivrant un certificat dédié à chaque service.

Principe de la chaîne de confiance

1. Root CA (l'autorité racine) :

- Installée sur les postes clients ;
- Durée de vie très longue (10-20 ans) ;
- Signe les autorités intermédiaires ;
- Hors ligne le reste du temps.

2. Intermediate CA (l'autorité intermédiaire) :

- Durée moyenne (5-10 ans) ;
- Signe les certificats de chaque service ;
- Reste active sur OPNsense.

3. Certificat de service :

- Installé sur le service concerné (Caddy, etc.) ;
 - Durée courte (1-2 ans) ;
 - Sert au protocole HTTPS de ce service uniquement.
-

1. Créer l'autorité racine (Root CA) :

| Seul certificat connu des clients.

- Dans OPNsense, aller dans la section **System** → **Trust** → **Authorities**.

- Cliquer sur **Add (+)**.
 - Renseigner :
 - **Descriptive name** : <Nom> Root CA
 - **Method** : Create an internal Certificate Authority
 - **Key length** : 4096 bit
 - **Digest Algorithm** : SHA512
 - **Lifetime** : 3650 (10 ans) ou plus
 - **Common Name (CN)** : <Nom> Root CA
 - Cliquer sur **Save**.
-

2. Créer l'autorité intermédiaire (Intermediate CA) :

Chargée de signer les certificats de chaque service.

- Dans OPNsense, aller dans la section **System** → **Trust** → **Authorities**.
 - Cliquer sur **Add (+)**.
 - Renseigner :
 - **Descriptive name** : <Nom> Intermediate CA
 - **Method** : Create an internal Certificate Authority
 - **Key length** : 4096 bit
 - **Digest Algorithm** : SHA512
 - **Lifetime** : 1825 (5 ans)
 - **Common Name (CN)** : <Nom> Intermediate CA
 - **Certificate Authority** : sélectionner <Nom> Root CA
 - Cliquer sur **Save**.
-

3. Générer un certificat dédié pour chaque service :

- Dans OPNsense, aller dans la section **System** → **Trust** → **Certificates**.
- Cliquer sur **Add (+)**.
- Renseigner :
 - **Method** : Create an internal Certificate
 - **Descriptive name** : Certificat <nom_du_service>
 - **Certificate Authority** : sélectionner <Nom> Intermediate CA
 - **Type** : Server Certificate
 - **Key length** : 2048 ou 4096
 - **Digest Algorithm** : SHA256

- **Lifetime** : 397 (env. 1 an) ou 825 (max supporté par Apple)
 - **Common Name (CN)** : <nom_du_service>.<domaine_local>
 - **Alternative Names (SANs)** :
 - Type : DNS → Value : <nom_du_service>.<domaine_local>
 - Cliquer sur **Save**.
 - Répéter cette étape pour chaque service à sécuriser.
-

4. Diffuser la confiance sur les postes clients :

Afin d'obtenir le cadenas vert, seul le certificat de l'autorité **racine** doit être installé sur les postes clients.

Les certificats de l'autorité intermédiaire et de chaque service sont ensuite validés automatiquement par la chaîne de confiance.

- Dans OPNsense, aller dans la section **Trust** → **Authorities**.
 - En face de <Nom> Root CA, cliquer sur **Export CA cert**.
 - Installation selon le poste :
 - **Windows** : double-clic → Installer → Machine locale → "Autorités de certification racines de confiance".
 - Sur le navigateur **Firefox** : Paramètres → Vie privée → Certificats → Afficher les certificats → Importer (magasin de certificats propre au navigateur).
 - Sur les navigateurs de type **Chromium** : Paramètres → Confidentialité et sécurité → Sécurité → Gérer les certificats → Installés par vous → Importer (magasin de certificats propre au navigateur).
-

Conclusion

- En cas d'ajout d'un nouveau service, il suffit de générer son certificat dédié (étape 3) sans devoir toucher aux postes clients ;
 - Cadenas vert sur chaque service ;
 - Risque de compromission limité au certificat concerné.
-

Voir aussi

La récupération des certificats côté service et leur intégration dans un reverse proxy sont détaillées dans la réalisation [Mise en place d'un reverse proxy Caddy pour l'accès aux services internes.](#)